INSTITUT UNIVERSITAIRE SAINT JEAN
SAINT JEAN INGÉNIEUR

Gestion avancée des identités avec Keystone et Tableau de bord Horizon personnalisé

Sécurité du Cloud: Cahier d'analyse
Master 2 SSI, Groupe 9
2025-2026

Rédigé par

- KINKEU Daniel
- KENGNE KONGNE Maximilien
- TSIDIE Berkam

Sous la supervision de M. NGUIMBUS

PLAN

Gestion avancée des identités avec Keystone et Tableau de bord Horizon personnalisé

Introduction

I- Contexte et objectif

II- Périmètre fonctionnel

III- Modélisation UML

IV- Livrables

Conclusion

Introduction

Dans un monde numérique en constante évolution, la sécurité des systèmes d'information constitue un enjeu essentiel pour les organisations publiques et privées. La multiplication des services en ligne et la complexité croissante des infrastructures exigent des solutions d'authentification et de gestion des identités toujours plus robustes.

C'est dans cette perspective que s'inscrit le présent projet, dont l'objectif est de concevoir une solution d'authentification avancée et de gestion des accès au sein d'un environnement cloud basé sur OpenStack. Ce cahier des charges présente les orientations générales, les besoins fonctionnels qui guideront la conception et la mise en œuvre de cette solution.

KEYSTONE
an OpenStack Community Project

Contexte, Justification du projet et Objectif

Contexte

Dans OpenStack, le système d'identité actuellement en place repose sur le service Keystone, qui assure l'authentification des clients, la gestion des utilisateurs, des projets et des rôles, la délivrance de tokens et la découverte des services. Keystone supporte l'intégration avec des annuaires externes, des mécanismes d'authentification pluggables, la fédération d'identités ainsi que des règles de policy pour le contrôle d'accès. Les évolutions prévues par ce projet interviendront principalement au niveau des points d'extension reconnus de Keystone (authentication plugins, federation, policy files et drivers) afin d'ajouter des capacités d'authentification multi-facteurs, une gestion plus fine des permissions et une meilleure traçabilité, sans remettre en cause les API ou les contrats existants.

Justification du projet

Bien que Keystone constitue une brique centrale et robuste pour la gestion des identités et des accès dans OpenStack, certaines limites apparaissent lorsqu'il s'agit de répondre à des exigences de sécurité et de gouvernance plus avancées. Ces limites justifient la mise en place d'une extension afin d'enrichir les fonctionnalités natives du service.

Justification du projet

Limites en matière d'authentification avancée

Keystone propose des mécanismes d'authentification standards (basés sur mot de passe, tokens, et parfois LDAP), mais son support natif de l'authentification multi-facteurs (MFA) reste limité et peu personnalisable.

Il ne permet pas, par exemple, de :

- choisir ou combiner différents types de seconds facteurs (OTP, SMS, application mobile, clé physique) selon les rôles ou les contextes d'accès ;
- imposer dynamiquement le MFA pour des rôles sensibles ou selon la localisation de l'utilisateur ;
- gérer facilement les préférences MFA des utilisateurs depuis une interface graphique intégrée.

Justification du projet

Limites dans la gestion granulaire des rôles et permissions

Le modèle RBAC (Role-Based Access Control) de Keystone est efficace mais statique :

- les rôles sont globalement définis, et les politiques d'accès sont décrites dans des fichiers JSON ou YAML souvent difficiles à maintenir.
- Il ne prend pas pleinement en charge un modèle ABAC (Attribute-Based Access Control) où les décisions d'accès pourraient dépendre d'attributs contextuels (heure, type de ressource, localisation, statut de l'utilisateur…).

Justification du projet

Manque d’outils de traçabilité et de supervision intégrés

- Keystone enregistre les logs d’activité, mais ne fournit pas nativement de tableau de bord de suivi des accès, tentatives échouées ou modifications de rôles.
- Les administrateurs doivent souvent consulter manuellement les journaux ou développer des outils externes pour consolider ces informations.

KEYSTONE
an OpenStack Community Project

Objectif

Dans le cadre de ce projet, il est proposé d'améliorer un système d'authentification existant en y intégrant des mécanismes multi-facteurs (MFA) et fédérés, ainsi qu'une gestion granulaire des rôles et permissions. Le projet prévoit également la personnalisation du tableau de bord Horizon, afin d'offrir une interface plus intuitive et adaptée aux différents profils d'utilisateurs.

KEYSTONE
an OpenStack Community Project

Périmètre fonctionnel

Périmètre fonctionnel

Keystone

- Permettre la gestion dynamique du MFA par l'administrateur
- Gérer les politiques de contrôle d'accès en fonction du niveau de sensibilité des rôles utilisateurs.
- Offrir la possibilité d'une authentification centralisée pour éviter la multiplication des comptes.

Périmètre fonctionnel

Plugins Horizon

- Afficher de l'état MFA et risques dans un dashboard
- Gérer UI des règles ABAC
- Visualiser de rapports de sécurité
- Interface simplifiée de gestion utilisateurs/projets
- Créer des plugins Horizon pour ajouter des fonctionnalités spécifiques à une organisation

  (ex : suivi budgétaire, rapportssécurité)

KEYSTONE
an OpenStack Community Project

Modélisation UML

1- Les différents cas d’utilisations

Acteur: Administrateur

UC1 – Activation dynamique du MFA

UC2 –Désactivation dynamique du MFA

UC3 – Création des règles d’accès contextuelles

UC4 – Modifier des règles d’accès contextuelles

UC5 – Supprimer des règles d’accès contextuelles

UC6 – Évaluation et application d’une règle ABAC lors d’un appel API

UC 7 – Génération d’un rapport de sécurité

UC8 – Visualisation de rapports de sécurité

UC9 – Plugin Horizon de suivi budgétaire

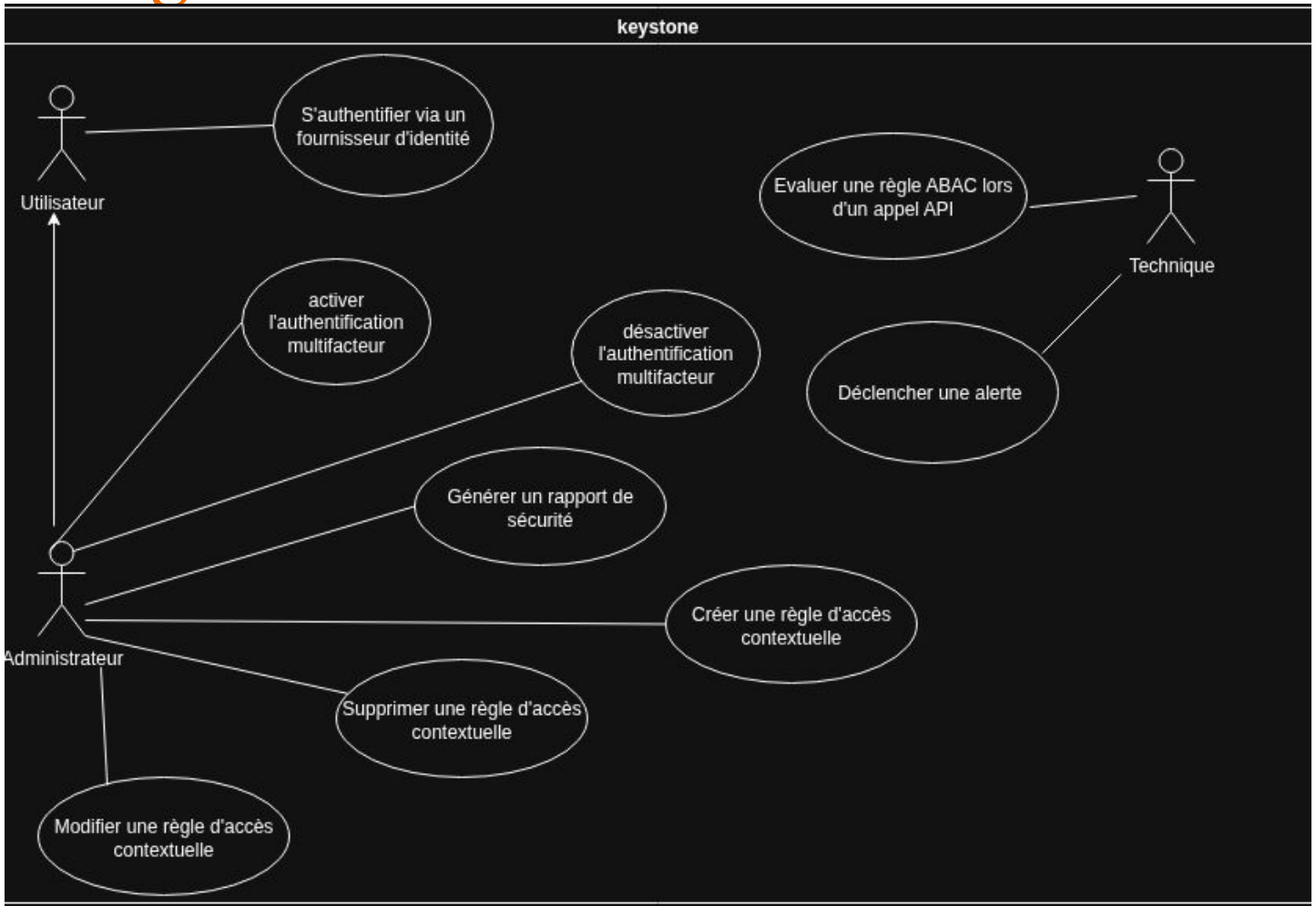
UC10– Consultation de la consommation temps réel

UC11– Déclenchement d'alertes et de restrictions budgétaires

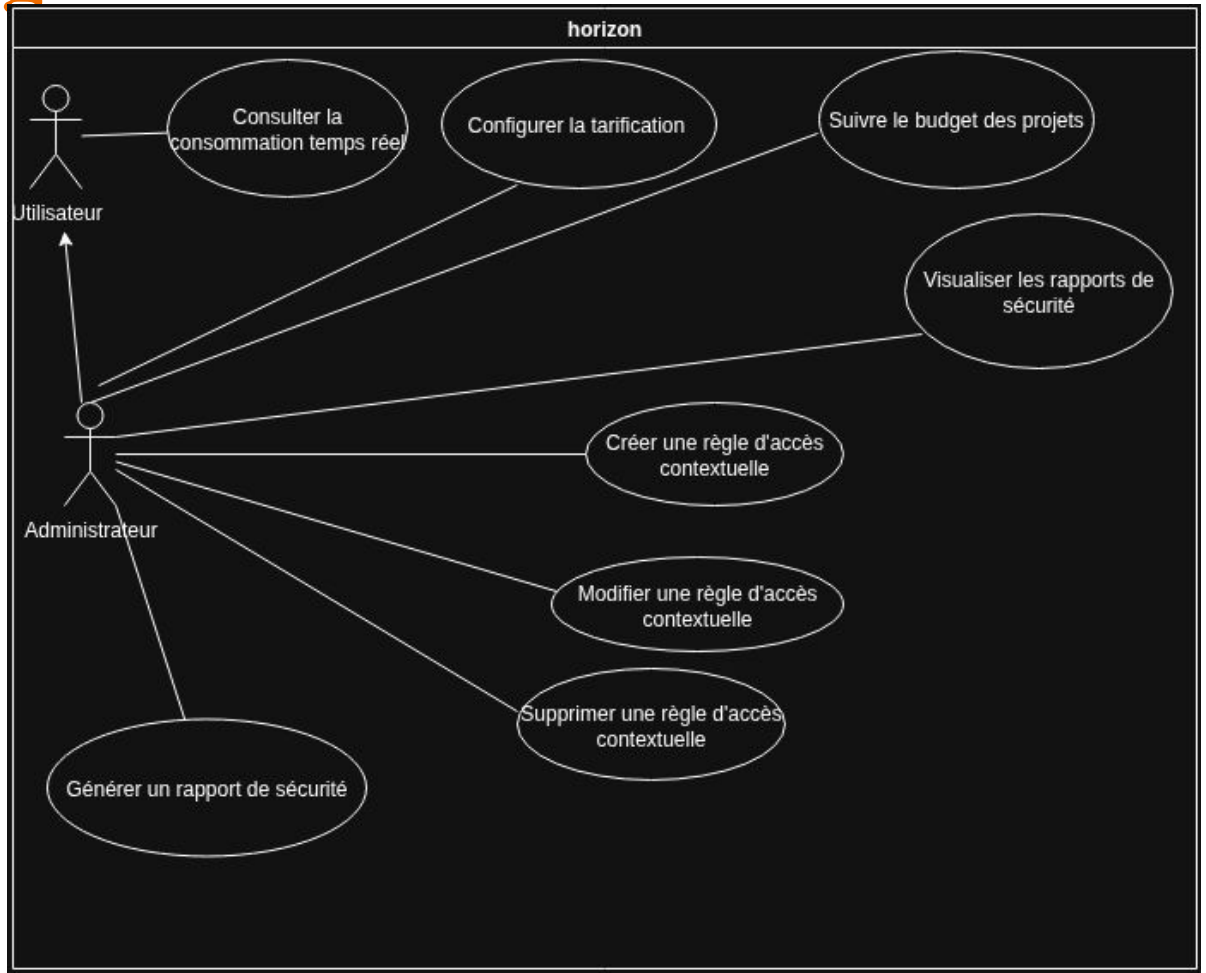
UC12– Authentification via un fournisseur d’identité fédéré

KEYSTONE
an OpenStack Community Project

2- Le diagramme de cas d’utilisation



2- Le diagramme de cas d’utilisation



3- Description textuelle des cas d’utilisations

UC-1: Activer MFA

Titre	Activer l'authentification multi-facteurs
Description	Permettre à l'administrateur de gérer dynamiquement l'activation du MFA pour un utilisateur.
Acteur(s)	Administrateur

précondition(s)	**postcondition(s)**
L'administrateur est connecté avec le rôle admin. L'utilisateur cible existe dans le domaine OpenStack et ne possède pas encore de second facteur actif.	L'utilisateur devra obligatoirement fournir un second facteur lors de sa prochaine connexion.

Scénario nominale

1. L'administrateur accède au module "Gestion des Utilisateurs" sur le tableau de bord Horizon.
2. Le système affiche la liste des utilisateurs avec leur état de sécurité actuel (MFA activé/désactivé).
3. L'administrateur sélectionne l'utilisateur spécifique et clique sur "Paramètres MFA".
4. L'administrateur coche l'option "Activer MFA" et sélectionne le type de facteur requis (ex: TOTP, Mail).
5. L'administrateur valide l'activation.
6. Le système met à jour l'attribut mfa_enabled dans la base de données Keystone et confirme l'opération.

Scénario alternatif

- L'administrateur décide de ne pas valider l'activation (clic sur "Annuler").
- Le système ferme la fenêtre sans modifier l'attribut mfa_enabled.
- L'authentification multifacteur est déjà activé.

UC-2:Désactiver MFA

Titre	Désactiver l'authentification multi-facteurs
Description	Permettre à l'administrateur de gérer dynamiquement la désactivation du MFA pour un utilisateur.
Acteur(s)	Administrateur

précondition(s)	**postcondition(s)**
L'administrateur est connecté avec le rôle admin. L'utilisateur cible existe dans le domaine OpenStack et possède un second facteur actif.	L'utilisateur pourra se connecter sans fournir de second facteur .

Scénario nominale

1. L'administrateur accède au module "Gestion des Utilisateurs" sur le tableau de bord Horizon.
2. Le système affiche la liste des utilisateurs avec leur état de sécurité actuel (MFA activé/désactivé).
3. L'administrateur sélectionne l'utilisateur spécifique et clique sur "Paramètres MFA".
4. L'administrateur coche l'option "Désactiver MFA".
5. L'administrateur valide l'opération.
6. Le système met à jour l'attribut mfa_enabled dans la base de données Keystone et confirme l'opération.

Scénario alternatif

- L'administrateur décide de ne pas désactiver(clic sur "Annuler").
- Le système ferme la fenêtre sans modifier l'attribut mfa_enabled.
- L'authentification multifacteur est déjà désactivé.

UC-3: Création de règles d'accès contextuelles

Titre	Créer une règle d'accès contextuelle
Description	Ce cas d'utilisation permet à l'administrateur de définir des politiques de sécurité dynamiques basées sur des attributs (heure, adresse IP, localisation) afin de restreindre ou d'autoriser l'accès à des ressources sensibles.
Acteur(s)	Administrateur

précondition(s)	**postcondition(s)**
L'administrateur est authentifié sur le tableau de bord Horizon avec les privilèges requis, Le service Keystone est configuré pour supporter les extensions ABAC.	La nouvelle règle est immédiatement active et sera évaluée lors de chaque demande d'accès aux ressources concernées.

Scénario nominale

1. L'administrateur se rend dans l'onglet "Sécurité Avancée" du tableau de bord Horizon.
2. L'administrateur clique sur "Ajouter une règle ABAC".
3. Le système affiche un formulaire demandant :
   a. Le nom de la règle (ex: "Accès restreint week-end").
   b. La ressource cible (ex: instances de production, volumes de données).
   c. L'action visée (ex: Start, Stop, Delete).
4. L'administrateur définit les attributs contextuels :
   a. Sélectionne le paramètre "Heure" et définit la plage (ex: 08:00 - 18:00).
   b. Sélectionne le paramètre "IP" et définit le réseau autorisé (ex: 192.168.1.0/24).
5. L'administrateur choisit l'effet de la règle : "Autoriser" ou "Refuser".
6. L'administrateur valide la création.
7. Le système traduit cette règle en format JSON/YAML compatible avec Keystone et l'enregistre dans la base de données des politiques.
8. Le système confirme le succès de l'opération par une notification visuelle.

Scénario alternatif

- Le système détecte qu'une règle avec le même nom ou les mêmes conditions existe déjà.
  - Le système affiche un message d'erreur : "Une règle identique existe déjà" et demande à l'administrateur de modifier les paramètres ou d'annuler.
- L'administrateur saisit une plage horaire ou une adresse IP mal formatée.
  - Le système souligne le champ et bloque la validation jusqu'à correction.

KEYSTONE
an OpenStack Community Project

UC-4: Modification des règles d'accès contextuelles

Titre	modifier une règles d'accès contextuelle
Description	Permet à l'administrateur de visualiser l'ensemble des règles actives, d'en modifier les paramètres (ex: changer une plage horaire) ou de les désactiver si elles ne sont plus nécessaires.
Acteur(s)	Administrateur

précondition(s)	**postcondition(s)**
L'administrateur est connecté. Des règles ABAC ont déjà été créées (UC3).	La règle est immédiatement active et sera évaluée lors de chaque demande d'accès aux ressources concernées.

Scénario nominale

1. L'administrateur accède à la "Liste des Politiques" sur Horizon.
2. Le système interroge Keystone et affiche un tableau récapitulatif (Nom, Cible, Attributs, État).
3. L'administrateur sélectionne une règle spécifique et clique sur "Modifier".
4. Le système ouvre un formulaire pré-rempli avec les conditions actuelles.
5. L'administrateur modifie une condition (ex: passage de l'heure de fin de 18h00 à 20h00).
6. L'administrateur valide la modification.
7. Le système met à jour le fichier de politique ou la base de données et confirme la mise à jour.

Scénario alternatif

- L'administrateur tente de modifier une règle de base d'OpenStack (ex: admin_required).
  - Le système bloque l'édition et affiche : "Règle système non modifiable via l'interface".
- Une erreur réseau survient lors de la mise à jour vers Keystone.
  - Le système affiche : "Échec de la mise à jour. La règle précédente reste en vigueur."

KEYSTONE
OpenStack Community Project

UC-5: Suppression des règles d'accès contextuelles

Titre	supprimer une règle d'accès contextuelle
Description	Permet de retirer définitivement une politique ABAC du système. Cette action est irréversible et modifie immédiatement le comportement de contrôle d'accès du cloud.
Acteur(s)	Administrateur

précondition(s)	**postcondition(s)**
L'administrateur est authentifié. Au moins une règle ABAC personnalisée existe dans le système.	La règle est définitivement retirée de la base de données de politiques. Tout accès précédemment autorisé (ou bloqué) par cette règle est immédiatement réévalué par Keystone selon les politiques par défaut restantes.

Scénario nominale

1. L'administrateur accède à l'interface de gestion des politiques sur le tableau de bord Horizon.
2. Le système affiche la liste des règles actives.
3. L'administrateur identifie la règle à supprimer et clique sur le bouton "Supprimer".
4. Le système affiche une fenêtre contextuelle de confirmation (pop-up) résumant les détails de la règle (Nom, Ressources affectées) et demandant une validation explicite.
5. L'administrateur confirme la suppression.
6. Le système envoie une requête DELETE à l'API Keystone.
7. Keystone retire l'entrée correspondante de sa base de données/fichier de politique et vide le cache des politiques pour forcer une réévaluation immédiate.
8. Le système rafraîchit la liste sur Horizon et affiche un message de succès : "La règle [Nom] a été supprimée avec succès".

Scénario alternatif

- L'administrateur clique sur "Annuler" dans la fenêtre de confirmation.
  - Le système ferme la fenêtre sans effectuer de modification. La règle reste active.
- Le système détecte que la règle est une règle "par défaut" ou qu'elle est requise pour la conformité minimale.
  - Le système bloque la suppression et affiche : "Action interdite : Cette règle est protégée par le système".

KEYSTONE
an OpenStack Community Project

UC-6: Évaluer une règle ABAC lors d'un appel API

Titre	Évaluer une règle ABAC lors d'un appel API
Description	Ce cas d'utilisation décrit le processus automatique de vérification des droits d'accès contextuels lorsqu'un utilisateur (ou un service) tente d'accéder à une ressource via une API OpenStack.
Acteur(s)	Système (Module d'extension Keystone).

précondition(s)	**postcondition(s)**
L'utilisateur possède un jeton d'authentification (Token) valide. Des règles ABAC ont été définies et chargées dans le moteur de politiques (UC-3).	Succès : L'action demandée par l'utilisateur est exécutée. Échec : L'action est bloquée, et un événement d'audit est enregistré dans les logs de sécurité de Keystone pour analyse ultérieure.

Scénario nominale

1. Le système reçoit une requête API (ex: POST /v3/servers pour créer une instance).
2. Le module d'interception de Keystone extrait les attributs de la requête :
    a. Sujet : Rôles et ID de l'utilisateur.
    b. Action : Type d'opération demandée (ex: compute:create).
    c. Environnement : Heure système actuelle, adresse IP source, zone géographique.
3. Le moteur d'évaluation récupère les règles ABAC correspondant à la ressource visée.
4. Le système compare les attributs de l'environnement avec les conditions de la règle (ex: "Est-ce que l'heure actuelle est comprise entre 08h et 18h ?").
5. Toutes les conditions sont remplies.
6. Le système accorde l'accès et transmet la requête au service concerné (ex: Nova).
7. Le système génère un jeton d'autorisation temporaire pour l'opération.

Scénario alternatif

- Le système détecte que l'attribut (ex: Heure = 22h00) ne correspond pas à la règle (ex: 08h00-18h00).
    - Le système rejette la requête.
    - Le système renvoie une erreur HTTP 403 (Forbidden) avec le message : "Accès refusé par la politique contextuelle".
- Le système ne parvient pas à récupérer un attribut nécessaire (ex: la localisation IP est masquée).
    - Par principe de précaution (Deny by default), le système refuse l'accès.

KEYSTONE
an OpenStack Community Project

UC-7: Générer un rapport de sécurité

Titre	Générer un rapport de sécurité
Description	Ce cas d'utilisation permet à l'administrateur d'extraire et de compiler les données de sécurité (tentatives de connexion, échecs MFA, violations de règles ABAC) sous forme de rapport (PDF/CSV) pour l'audit et la surveillance.
Acteur(s)	Administrateur

précondition(s)	**postcondition(s)**
L'administrateur est connecté à Horizon. Le service de logging a collecté des données sur une période donnée.	Un fichier contenant les statistiques de sécurité est généré et stocké temporairement ou téléchargé sur le poste de l'administrateur.

Scénario nominale

1. L'administrateur accède à la section "Audit & Reporting" du tableau de bord Horizon.
2. L'administrateur sélectionne les filtres du rapport :
    a. Période (ex: les 30 derniers jours).
    b. Type d'événements (ex: Échecs d'authentification, Accès refusés par ABAC).
    c. Utilisateurs ou projets spécifiques.
3. L'administrateur choisit le format de sortie (ex: PDF pour présentation ou CSV pour analyse Excel).
4. L'administrateur clique sur "Générer le rapport".
5. Le système interroge les journaux d'audit (logs Keystone) et agrège les données.
6. Le système prépare le fichier et affiche un lien de téléchargement.
7. L'administrateur télécharge le fichier.

Scénario alternatif

- Le système constate qu'aucun événement ne correspond aux filtres sélectionnés.
    - Le système affiche un message : "Aucune donnée trouvée pour cette période. Veuillez modifier vos filtres."
- Le service de journalisation est injoignable ou les fichiers de logs sont corrompus.
    - Le système affiche : "Erreur lors de la récupération des données d'audit."

KEYSTONE
an OpenStack Community Project

UC-8: Visualisation de rapports de sécurité

Titre	Visualiser le rapports de sécurité
Description	Ce cas d'utilisation permet à l'administrateur de consulter les statistiques et les indicateurs de sécurité (KPI) via un tableau de bord interactif sur Horizon.
Acteur(s)	Administrateur

précondition(s)	**postcondition(s)**
Le module "Dashboard de Sécurité" est actif et alimenté par les données de Keystone (échecs MFA, refus ABAC).	L'administrateur a une vision claire de l'état de sécurité du cloud. Aucun fichier n'est créé sur le disque (contrairement à l'UC-7).

Scénario nominale

1. L'administrateur se connecte au tableau de bord Horizon et sélectionne le menu "Vue d'ensemble de la sécurité".
2. Le système affiche une interface composée de graphiques et de tableaux récapitulatifs.
3. L'administrateur survole les graphiques pour voir les détails (infobulles).
4. L'administrateur utilise les filtres interactifs (ex: sélectionner uniquement "Échecs MFA") pour mettre à jour la vue en temps réel.
5. Le système actualise les données affichées en interrogeant l'API de monitoring.
6. L'administrateur consulte la liste des 10 dernières alertes critiques en bas de page.

Scénario alternatif

- Certains services ne remontent pas leurs logs (ex: module ABAC indisponible).
  - Le système affiche les graphiques disponibles mais marque les zones manquantes avec un message : "Source de données [ABAC] hors ligne".
- Un utilisateur sans rôle d'audit tente d'accéder à la page.
  - Le système redirige vers une page 403 (Accès interdit) et logue la tentative d'accès non autorisé.

KEYSTONE

UC-9-1: Configuration de la tarification

Titre	Configurer la tarification
Description	Permet à l'administrateur de définir les coûts unitaires des ressources OpenStack (vCPU, RAM, Stockage)
Acteur(s)	Administrateur

précondition(s)	**postcondition(s)**
L'administrateur est authentifié sur Horizon. Les projets cibles sont déjà créés dans Keystone.	Le projet possède désormais un cadre financier. Toute nouvelle consommation mesurée par Ceilometer (UC-9.2) sera multipliée par ces nouveaux tarifs.

Scénario nominale

1. L'administrateur accède au menu "Configuration Budgétaire" sur Horizon.
2. L'administrateur saisit les coûts unitaires (Grille tarifaire) :
    a. Coût par vCPU / heure.
    b. Coût par Go de RAM / heure.
    c. Coût par Go de stockage (Cinder) / mois.
3. L'administrateur sélectionne un Projet spécifique.
4. Le système valide la cohérence des données (ex: les montants ne sont pas négatifs).
5. L'administrateur confirme l'enregistrement.
6. Le système stocke ces paramètres dans la base de données du module de facturation et confirme le succès.

Scénario alternatif

- L'administrateur saisit un coût nul ou erroné (ex: texte à la place de chiffres).
    - Le système affiche un message d'erreur et surligne le champ concerné.

KEYSTONE
an OpenStack Community Project

UC-9-2: Configuration des seuils

Titre	Configurer la tarification
Description	Permet à l'utilisateur d'allouer un budget spécifique à chaque projet avec des seuils d'alerte.
Acteur(s)	Utilisateur

précondition(s)	**postcondition(s)**
L'utilisateur est authentifié sur Horizon. Les projets cibles sont déjà créés dans Keystone.	Le projet possède désormais un cadre financier. Toute nouvelle consommation mesurée par Ceilometer (UC-9.2) sera multipliée par ces nouveaux tarifs.

Scénario nominale

1. L'utilisateur accède au menu "Configuration Budgétaire" sur Horizon.
2. L'utilisateur sélectionne un Projet spécifique.
3. L'utilisateur définit :
    a. Le Budget Total (ex: 500.000 Fcfa).
    b. Les Seuils d'Alerte (ex: notification à 70%, 85% et 95% de consommation).
4. Le système valide la cohérence des données (ex: les montants ne sont pas négatifs).
5. L'utilisateur confirme l'enregistrement.
6. Le système stocke ces paramètres dans la base de données du module de facturation et confirme le succès.

Scénario alternatif

- Le projet sélectionné n'a pas de limites de ressources dans Keystone.
    - Le système affiche un avertissement : "Attention, aucun quota technique n'est défini pour ce projet. Le budget risque d'être consommé sans limite physique."

KEYSTONE
an OpenStack Community Project

UC-10: Consultation de la consommation temps réel

Titre	Consulter la consommation temps réel
Description	Permet de visualiser l'état actuel des dépenses du projet en interrogeant dynamiquement les services de télémétrie d'OpenStack.
Acteur(s)	Utilisateur

précondition(s)	**postcondition(s)**
La grille tarifaire a été configurée (UC-9.1). L'utilisateur possède un rôle lui permettant de voir les ressources de son projet.	L'utilisateur a une vision honnête et traçable de ce qu'il consomme. Aucune donnée de consommation n'est modifiée, elle est uniquement lue (lecture seule).

Scénario nominale

1. L'utilisateur se connecte à son tableau de bord Horizon et clique sur "Ma Consommation".
2. Le système lance une requête vers l'API Gnocchi pour récupérer les agrégats de mesures sur les 24 dernières heures (ou le mois en cours).
3. Le système identifie les compteurs clés (meters) :
    a. cpu_util : pourcentage d'utilisation des processeurs.
    b. vcpus : nombre d'instances actives.
    c. disk.usage : volume de données stockées.
4. Le moteur de calcul applique les tarifs stockés en base (ex: Nombre_vCPUs X Heures X Tarif_Unitaire).
5. Le système affiche une interface détaillée comprenant :
    a. Le Coût Total Actuel.
    b. Un Graphique d'utilisation par catégorie de ressource.
    c. Le Timestamps : "Dernière synchronisation avec Ceilometer à 14h05" (pour la transparence).
6. L'utilisateur peut forcer un rafraîchissement des données via un bouton "Actualiser".

Scénario alternatif

- Le système détecte que Ceilometer n'a pas envoyé de données depuis plus de 30 minutes.
- Le système affiche un bandeau d'information : "Données en cours de synchronisation, l'affichage peut être partiel".
- L'API de stockage des métriques ne répond pas.
- Le système affiche les dernières données mises en cache et précise la date de la dernière lecture réussie.

KEYSTONE
an OpenStack Community Project

UC-11: Déclenchement d'alertes

Titre	Déclencher une alerte
Description	Le système compare de manière autonome la consommation calculée (UC-9.2) aux seuils définis (UC-9.1). Il prend des mesures de notification ou de restriction technique pour garantir l'intégrité financière.
Acteur(s)	Système

précondition(s)	**postcondition(s)**
La télémétrie Ceilometer/Gnocchi est fonctionnelle. Un budget et des seuils d'alerte ont été configurés pour le projet.	Le risque financier est maîtrisé. Aucune dépense supplémentaire non autorisée n'est possible.

Scénario nominale

1. Le système exécute une tâche planifiée (ex: toutes les heures) pour vérifier l'état financier de chaque projet.
2. Le système calcule le coût total consommé à l'instant T.
3. Vérification des seuils d'alerte : Si le coût franchit un seuil (ex: 80%), le système déclenche l'envoi d'un e-mail d'alerte aux administrateurs du projet.
4. Vérification du plafond (Hard Limit) : Si le coût atteint 100% du budget alloué :
    a. Le système appelle l'API Keystone pour mettre à jour les quotas du projet.
    b. Le système force le quota de création de nouvelles ressources à zéro (ex: instances=0, volumes=0).
5. Le système consigne l'action dans les logs d'audit : "Projet X : Quotas verrouillés pour cause de dépassement budgétaire".
6. L'interface Horizon affiche un bandeau rouge sur le tableau de bord du projet concerné.

Scénario alternatif

- Le système identifie que le projet est marqué comme "Critique" (ex: Production).
    - Au lieu de bloquer, le système envoie une alerte de priorité haute mais ne restreint pas les ressources pour éviter une interruption de service (Business Continuity).

KEYSTONE
an OpenStack Community Project

UC-12: Authentification via un fournisseur d'identité fédéré

Titre	Authentification via un fournisseur d'identité fédéré
Description	Il permet de lier Keystone à un fournisseur externe (IdP) comme Google, Keycloak ou un Active Directory via les protocoles SAML2 ou OpenID Connect (OIDC). Permet à un utilisateur de se connecter au Cloud OpenStack en utilisant ses identifiants d'entreprise ou de réseaux sociaux, sans que ses mots de passe ne transitent par Keystone.
Acteur(s)	Utilisateur

précondition(s)	**postcondition(s)**
Un lien de confiance (Federation Link) est établi entre Keystone et l'IdP. Le mapping des protocoles (SAML/OIDC) est configuré pour transformer les attributs externes en groupes/rôles Keystone.	Une session utilisateur est ouverte. L'utilisateur est "mappé" dynamiquement sans avoir de compte local permanent dans la base de données Keystone (Provisioning à la volée). Le jeton de session indique explicitement que l'authentification est de type federated.

Scénario nominale

1. L'utilisateur accède à la page de connexion Horizon.
2. Au lieu de saisir ses identifiants, il sélectionne la méthode d'authentification (ex: "Connexion via Keycloak") dans une liste déroulante.
3. Le système (Horizon) redirige l'utilisateur vers l'URL d'authentification du Fournisseur d'Identité (IdP).
4. L'utilisateur s'authentifie sur la plateforme externe (ex: saisie de login/MDP ou biométrie sur son portail d'entreprise).
5. Après succès, l'IdP renvoie l'utilisateur vers Keystone avec une assertion signée (contenant ses informations : email, groupe, nom).
6. Le module Keystone-Federation valide la signature de l'assertion.
7. Le système applique les règles de mapping pour associer l'utilisateur externe à un projet et un rôle local (ex: le groupe "Dev" chez l'IdP devient "Member" sur OpenStack).
8. Keystone génère un jeton (token) de session et l'utilisateur est redirigé vers son tableau de bord.

Scénario alternatif

- L'utilisateur échoue à se connecter sur l'IdP (mauvais mot de passe).
  - L'IdP ne renvoie pas l'utilisateur vers OpenStack ou renvoie une erreur. L'accès au Cloud est bloqué à la source.
- L'IdP valide l'identité, mais Keystone ne trouve aucune règle pour transformer les attributs reçus en rôles locaux.
  - Le système affiche : "Authentification réussie, mais vous n'avez aucun droit d'accès sur ce Cloud. Contactez votre administrateur."

Livrables

Livrables

- Dossier de conception
- Dossier de réalisation
- Rapport de déploiement
- Rapport du projet

Conclusion

Le projet présenté à travers ce cahier d'analyse ambitionne de fournir une solution complète et sécurisée de gestion des identités et des accès dans un environnement OpenStack. En combinant des technologies d'authentification modernes, une gestion granulaire des permissions et une interface Horizon adaptée aux besoins métiers, cette solution contribuera à renforcer la gouvernance et la confiance au sein du système d'information.

La mise en œuvre de cette solution représente ainsi une avancée importante vers un modèle de sécurité plus robuste, plus flexible et centré sur l'utilisateur, garantissant une meilleure protection des données et une expérience optimisée pour l'ensemble des acteurs de l'organisation.

Merci pour votre attention